RaceDay API Endpoint Plan

Application roles: Organiser and Participant. Organisers are provisioned through a controlled process and cannot self-register. Participants register through the public registration endpoint. The roles are stored in separate tables, so an account cannot hold both roles.

Request bodies: all fields listed in braces are compulsory unless marked optional. Invalid or missing fields return 400. Protected routes require an authenticated session. Login does not require a pre-existing session, but the Role Required column identifies the account type accepted. Authentication is established by an HTTP-only cookie and session state.

HTTP Method	Route	Description	Role Required	Requested Body / Query	Expected Response
POST	/api/auth/register	Register a Participant account.	Public registration, Participant created	{ FirstName, LastName, Email, Password }	201 Created; 400 validation error; 409 duplicate email.
POST	/api/auth/login	Authenticate an account and establish a session. Role is mandatory in the body.	Participant or Organiser, role specified in body	{ Email, Password, Role }	200 account profile and auth cookie; 400 invalid body/role; 401 invalid credentials.
POST	/api/auth/provision-organiser	Provision an Organiser account using a trusted deployment secret.	Provisioning key required, no public self-registration	Header: X-Provisioning-Key. Body: { FirstName, LastName, Email, TemporaryPassword }	201 created; 400 invalid body; 401 invalid provisioning key; 409 duplicate email.
POST	/api/auth/logout	Clear authentication cookie and session.	Authenticated	None	204 No Content.
GET	/api/users/me	Get the authenticated user's own profile.	Participant or Organiser	None	200 profile; 401 unauthenticated; 404 account missing.
PUT	/api/users/me	Update own first name, last name, and email. Role cannot be changed here.	Participant or Organiser	{ FirstName, LastName, Email }	200 updated profile; 400 invalid body; 401 unauthenticated; 409 duplicate email.
GET	/api/events	Browse events, venues, and event categories.	Public	None	200 list of events.
GET	/api/events/{id}	Get one event and its categories.	Public	None	200 event; 404 not found.
POST	/api/events	Create an event owned by the authenticated Organiser.	Organiser	{ Name, Description, EventDate, EventType, VenueID }	201 created; 400 invalid event type/venue/body; 401 unauthenticated; 403 wrong role.
PUT	/api/events/{id}	Update an event owned by the authenticated Organiser.	Organiser, event owner	{ Name, Description, EventDate, EventType, VenueID }	204 updated; 400 invalid input; 401 unauthenticated; 403 not owner; 404 not found.
DELETE	/api/events/{id}	Delete an event with no dependent categories.	Organiser, event owner	None	204 deleted; 401 unauthenticated; 403 not owner; 404 not found; 409 dependencies exist.
GET	/api/venues	List venues.	Public	None	200 list of venues.
GET	/api/venues/{id}	Get a venue.	Public	None	200 venue; 404 not found.
POST	/api/venues	Create a venue.	Organiser	{ Name, AddressLine, City, Province, Latitude, Longitude }	201 created; 400 invalid input; 401 unauthenticated; 403 wrong role.
PUT	/api/venues/{id}	Update venue information.	Organiser	{ Name, AddressLine, City, Province, Latitude, Longitude }	204 updated; 400 invalid input; 401 unauthenticated; 403 wrong role; 404 not found.
DELETE	/api/venues/{id}	Delete a venue not referenced by an event.	Organiser	None	204 deleted; 401 unauthenticated; 403 wrong role; 404 not found; 409 referenced by event.
GET	/api/categories?eventId={id}	List all categories, optionally filtered by event.	Public	Query: eventId optional	200 list of categories.
GET	/api/categories/{id}	Get a category.	Public	None	200 category; 404 not found.
POST	/api/categories/event/{eventId}	Create a category for an event owned by the Organiser.	Organiser, event owner	{ Name, DistanceKm, MaxParticipants, EntryFee }	201 created; 400 invalid input; 401 unauthenticated; 403 not owner; 404 event missing.
PUT	/api/categories/{id}	Update a category for an owned event.	Organiser, event owner	{ Name, DistanceKm, MaxParticipants, EntryFee }	204 updated; 400 invalid input; 401 unauthenticated; 403 not owner; 404 missing; 409 capacity conflict.
DELETE	/api/categories/{id}	Delete a category with no enrolments.	Organiser, event owner	None	204 deleted; 401 unauthenticated; 403 not owner; 404 missing; 409 enrolments exist.
GET	/api/enrolments	Participants see their own enrolments. Organisers see enrolments for their own events.	Participant or Organiser, records scoped by ownership	None	200 scoped enrolment list; 401 unauthenticated.

POST	/api/enrolments	Enrol the authenticated Participant in a category.	Participant	{ CategoryID }	201 created; 400 invalid body; 401 unauthenticated; 403 wrong role; 404 category missing; 409 duplicate or full category.
PUT	/api/enrolments/{id}/cancel	Cancel own enrolment.	Participant, enrolment owner	None	204 cancelled; 401 unauthenticated; 403 not owner; 404 missing; 409 already cancelled.
GET	/api/results	Participants see their own results. Organisers see results for their own events.	Participant or Organiser, records scoped by ownership	None	200 scoped results; 401 unauthenticated.
POST	/api/results	Record a result for an enrolment in an owned event.	Organiser, event owner	{ EnrolmentID, FinishTime, Position }	201 created; 400 invalid time/body; 401 unauthenticated; 403 not owner; 404 enrolment missing; 409 result exists.
PUT	/api/results/{id}	Update a result in an owned event.	Organiser, event owner	{ EnrolmentID, FinishTime, Position }	204 updated; 400 invalid body or mismatched enrolment; 401 unauthenticated; 403 not owner; 404 missing.
DELETE	/api/results/{id}	Delete a result in an owned event.	Organiser, event owner	None	204 deleted; 401 unauthenticated; 403 not owner; 404 missing.
POST	/api/participants/login	Authenticate a Participant account and establish a session.	Participant, role required in body	{ Email, Password, Role: Participant }	200 profile and auth cookie; 400 invalid body/role; 401 invalid credentials.
POST	/api/organisers/login	Authenticate a provisioned Organiser account and establish a session.	Organiser, role required in body	{ Email, Password, Role: Organiser }	200 profile and auth cookie; 400 invalid body/role; 401 invalid credentials.
PUT	/api/users/me/password	Change own password after verifying the current password.	Participant or Organiser	{ CurrentPassword, NewPassword }	204 No Content; 400 incorrect current password or invalid input; 401 unauthenticated; 404 account missing.
GET	/api/organisers/me	Role-specific alias for the authenticated Organiser profile.	Organiser	None	200 profile; 401 unauthenticated; 403 wrong role.
PUT	/api/organisers/me	Update own Organiser profile.	Organiser	{ FirstName, LastName, Email }	200 profile; 400 invalid body; 401 unauthenticated; 409 duplicate email.
GET	/api/participants/me	Role-specific alias for the authenticated Participant profile.	Participant	None	200 profile; 401 unauthenticated; 403 wrong role.
PUT	/api/participants/me	Update own Participant profile.	Participant	{ FirstName, LastName, Email }	200 profile; 400 invalid body; 401 unauthenticated; 409 duplicate email.
GET	/api/events/{eventId}/ categories	List categories for one event.	Public	None	200 category list.
POST	/api/events/{eventId}/ categories	Create a category for an event owned by the Organiser.	Organiser, event owner	{ Name, DistanceKm, MaxParticipants, EntryFee }	201 created; 400 invalid body; 403 not owner; 404 event missing.
GET	/api/events/{eventId}/ enrolments	List enrolments for an event owned by the Organiser.	Organiser, event owner	None	200 enrolments; 403 not owner; 404 event missing.
POST	/api/events/{eventId}/ enrolments	Enrol in a category belonging to this event.	Participant	{ CategoryID }	201 created; 400 category does not belong to event; 409 duplicate/full category.
GET	/api/enrolments/{id}	Get an enrolment if it belongs to the Participant or an event owned by the Organiser.	Participant or Organiser, owner check	None	200 enrolment; 403 forbidden; 404 missing.
PUT	/api/enrolments/{id}	Update enrolment status for an owned event.	Organiser, event owner	{ Status }	204 updated; 400 invalid status; 403 not owner; 404 missing.
DELETE	/api/enrolments/{id}	Cancel an enrolment as its Participant or the event Organiser.	Participant or Organiser, owner check	None	204 cancelled; 403 forbidden; 404 missing.
GET	/api/events/{eventId}/results	List results for an event owned by the Organiser.	Organiser, event owner	None	200 results; 403 not owner; 404 event missing.
GET	/api/participants/me/results	List results for the authenticated Participant.	Participant	None	200 result list; 401 unauthenticated; 403 wrong role.
GET	/api/enrolments/ {enrolmentId}/results	Get a result linked to an enrolment owned by the caller or their event.	Participant or Organiser, owner check	None	200 result; 403 forbidden; 404 enrolment/result missing.

Security and data rules

- Passwords are hashed using ASP.NET Core Identity PasswordHasher. Raw passwords and password hashes are never returned by API responses.
- Participant registration cannot create an Organiser. Organiser provisioning requires a deployment secret and must only be performed by trusted operators.
- Profile endpoints act on the authenticated account. The API does not accept user IDs from the client to select the profile being updated.
- Organisers may only modify events, categories, and results associated with events they own. Participant enrolments and results are restricted to the authenticated Participant.
- EventType must be Run, Walk, or Cycle. Enrolment capacity and duplicate enrolment checks are enforced by the API.

- Swagger UI is available at /swagger. Login first in the same browser session to test protected endpoints.